情報処理安全確保支援士試験　科目A-2　中分類25 情報セキュリティ対策　#14

セキュアプロトコルとメールのセキュリティ

午前 II で最も多く出る分野。同じ問題がくり返し出る

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、IEEE 802.1X、Wi-Fi Alliance、各 RFC、迷惑メール対策推進協議会など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類25 小分類6「技術規格・プロトコル」

1 無線 LAN と 802.1X
サプリカント・オーセンティケータ・EAP-TLS・RADIUS・AAA、WPA3・Enhanced Open・プライバシーセパレータ

2 TLS・IPsec・SSH・DNS
TLS 1.3 の暗号スイート・常時 TLS・DTLS・QUIC、IPsec、SSH、DNSSEC・DoH

3 電子メール
OP25B・IP25B・SMTP-AUTH、SPF・DKIM・DMARC、STARTTLS・S/MIME・PGP・IMAPS、無害化

平成31～令和7年度で41問（全体で一番多い）

テーマ	回数
OP25B・IP25B	5回
802.1X・EAP-TLS・RADIUS	8回
DNSSEC	4回
無線 LAN の規格・Enhanced Open	6回
SPF・DKIM・DMARC・SMTP-AUTH	7回
TLS・DTLS・IPsec・SSH	7回

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類25 小分類6／IPA 午前 II 平成31年度春期～令和7年度秋期（このPDFの問題演習を参照）

第1章

無線 LAN と IEEE 802.1X

3つの役割と、RADIUS のどちら側か。

802.1X の3つの役割と RADIUS

サプリカント
PC・スマホ
認証を要求する側

⇄ EAP ⇄

オーセンティケータ
アクセスポイント・スイッチ
RADIUS クライアント

⇄ RADIUS ⇄

認証サーバ
RADIUS サーバ
利用者情報を管理

R4春・R6秋 問17 の選択肢	判定
PC にサプリカント+RADIUS クライアント	PC は RADIUS を話さない
AP にオーセンティケータ+RADIUS クライアント	正解
AP にサプリカント+RADIUS サーバ	×
サーバにオーセンティケータ+RADIUS サーバ	×

EAP-TLS：証明書で**サーバとクライアントの相互認証**（R1秋・R3秋）。
PEAP はサーバ証明書＋パスワード。

AAA：Authentication・Authorization・**Accounting**（R6秋 問1）。

EAP は認証の**枠組み**。暗号化の規格ではない。

出典：IEEE 802.1X-2020／RFC 3748・RFC 5216・RFC 2865／IPA 午前 II 令和6年度春期 問14・秋期 問17、令和7年度秋期 問17

無線 LAN の方式を見分ける

方式	認証	暗号化と特徴
WPA2-Personal	共通のパスフレーズ（PSK）	盗聴したハンドシェイクからパスフレーズを総当たりされうる
WPA3-Personal	パスフレーズ（SAE）	オフライン辞書攻撃に強い・前方秘匿性
WPA2/3-Enterprise	802.1X で利用者ごと	認証後に**動的に配布される鍵**で暗号化（H31春・R3秋・R5春）
Enhanced Open	なし	パスワード入力なしで**暗号化**（RFC 8110 の OWE）。偽 AP は防げない

R6春 問12：Enhanced Open で「新規に」できたのは「入力なしで**暗号化**」。入力なしの**接続**は前からある。

プライバシーセパレータ（R4秋 問17）：同じ AP の端末同士の通信を禁止。SSID 隠し・MAC フィルタとは別。

出典：Wi-Fi Alliance「WPA3 Specification」「Enhanced Open」／RFC 8110／IPA 午前 II 令和3年度春期 問17・令和6年度春期 問12

第2章

TLS・IPsec・SSH・DNS の保護

どの層で、何を守るか。

層ごとの暗号化プロトコル

アプリケーション層
SSH（遠隔ログイン・TCP 22）、S/MIME・PGP（メール本文）

トランスポート層の上
TLS（TCP）、**DTLS（UDP）**、QUIC（UDP に TLS 1.3 内蔵）

ネットワーク層
IPsec：ESP（暗号化＋認証）、AH（認証だけ）、IKE（鍵交換）

データリンク層
WPA2/3（無線）、MACsec（有線）

過去問	答え
IPv6 をネットワーク層で暗号化	IPsec
UDP のペイロードを暗号化	DTLS
暗号化と認証つきの遠隔ログイン	SSH
認証とアカウンティングの情報	RADIUS

> L2TP はトンネルだけで暗号化しない（IPsec と組み合わせる）。

出典：RFC 4301〜4303・RFC 9147・RFC 9000・RFC 4251／IPA 午前 II 令和4年度秋期 問13・令和5年度秋期 問15・令和6年度秋期 問15

TLS 1.3 で何が変わったか

	TLS 1.2	TLS 1.3
鍵交換	RSA も可	(EC)DHE だけ → **常に前方秘匿性**
暗号	CBC・RC4 も	**AEAD だけ**(AES-GCM・ChaCha20-Poly1305)
暗号スイート	鍵交換+署名+暗号+MAC	AEAD+ハッシュ
往復	2往復	1往復(0-RTT もある)

```
TLS_AES_128_GCM_SHA256
     └AEAD──────┘ └ハッシュ┘
```

SSL 3.0・TLS 1.0・TLS 1.1 は**廃止**(RFC 8996、2021年)。

R4春 問15: クライアント証明書は **IC カードに入れられ**、PC を限定しなくてよい(正解)。サーバ証明書に IP アドレスは必須ではない。

常時 TLS(R1秋 問14): 中間者の盗聴・改ざんを防ぎ、証明書で偽サイトを見分けやすく。SQL インジェクションは防げない。

出典:RFC 8446 TLS 1.3・RFC 8996 Deprecating TLS 1.0 and TLS 1.1／IPA 午前 II 令和5年度秋期 問2・令和4年度春期 問15・令和元年度秋期 問14

DNSSEC と DoT・DoH

権威 DNS サーバ
ゾーンの秘密鍵で**署名**（RRSIG）

→

リゾルバ
公開鍵（DNSKEY）で**検証**
上位の DS で信頼の連鎖

DNSSEC で	判定
応答の作成元の正当性と完全性	できる
通信の暗号化・盗聴防止	できない
DoS 攻撃の防止	できない
似た文字・入力ミスのドメイン	できない

R5秋 問13：署名するのは**権威サーバ**、受信時に検証するのは**リゾルバ**。
「暗号化」の選択肢は全部誤り。

DoT（TCP 853）・DoH（443）：問合せを暗号化して盗聴を防ぐ。
DNSSEC とは目的が違い、併用できる。

DoH は Web に紛れて組織の DNS フィルタを迂回されうる。

出典：RFC 4033〜4035（DNSSEC）・RFC 7858（DoT）・RFC 8484（DoH）／IPA 午前 II 令和4年度春期 問13・令和5年度秋期 問13

第3章

電子メールのセキュリティ

出口で止め、送信元を確かめ、中身を守る。

OP25B・IP25B と SMTP-AUTH

ISP A の利用者の PC から

感染 PC → 外部のメールサーバ:25
× OP25B（ISP A の出口で止める）

正規の利用者 → ISP A のメールサーバ:587
○ SMTP-AUTH で認証して送信（サブミッションポート）

他社 ISP の動的 IP → ISP A のメールサーバ:25
× IP25B（入口で止める）

説明	正体
管理下の動的 IP から管理外の 25 番を禁止	OP25B
送信時に ID とパスワードで認証	SMTP-AUTH
POP で認証済みなら送信を許可	POP before SMTP
送信元サーバが DNS に登録されているか	SPF

> OP25B の誤りの選択肢は「ICMP」「外から来るスパム」。止めるのは**外向きの 25 番**。

出典：迷惑メール対策推進協議会「迷惑メール対策ハンドブック」／RFC 4954・RFC 6409／IPA 午前 II 令和7年度春期 問17・令和2年度 問16・問17・令和4年度秋期 問14

送信ドメイン認証：SPF・DKIM・DMARC

仕組み	送信側が DNS に置くもの	受信側が確かめること	転送に
SPF	送信してよいサーバの IP（SPF レコード）	接続してきた IP が含まれるか	弱い
DKIM	署名の**公開鍵**	ヘッダの署名を公開鍵で検証	強い（改変には弱い）
DMARC	**失敗時の処理方針**とレポート先	SPF/DKIM の結果と From のドメインの一致	―

```
_dmarc.example.jp TXT
"v=DMARC1; p=none; rua=mailto:dmarc@example.jp"
```

p=none（監視）→ quarantine（隔離）→ reject（拒否）と段階的に。

過去問：SPF の導入で送信側がすること＝DNS に SPF レコード（H31春・R4秋）。署名して公開鍵で検証＝DKIM（R1秋・R5春）。失敗時の処理方針＝DMARC（R6秋）。

出典：RFC 7208（SPF）・RFC 6376（DKIM）・RFC 7489（DMARC）／IPA 午前 II 令和4年度秋期 問15・令和5年度春期 問15・令和6年度秋期 問10

メールの暗号化：どこを守るか

方式	公開鍵の単位	守る範囲
PGP	メールアドレスごと	本文（端から端）
S/MIME	メールアドレスごと	本文（端から端）
SMTP over TLS	メールサーバごと	サーバ間の通信路
IMAPS・POP3S	メールサーバごと	受信の通信路（本文含む）
APOP	ー	パスワードだけ（本文は平文）

R4秋・R6春 問16 の組合せは「アドレス・アドレス・サーバ」。

STARTTLS は平文から切り替える方式。応答を消されると平文に落ちる → MTA-STS・DANE で TLS を強制。

無害化（CDR）：添付ファイルのマクロ・スクリプトを除去したり PDF・画像に変換したりして渡す。未知のマルウェアにも効く。

R4春・R5秋 問16：スマホの受信を本文ごと暗号化＝IMAPS。

出典：RFC 8551（S/MIME 4.0）・RFC 3207・RFC 8461・RFC 8314／IPA 午前 II 令和6年度春期 問16・令和5年度秋期 問16

まとめ：本番での問われ方

802.1X：サプリカント＝PC、オーセンティケータ＝AP（RADIUS クライアント）、認証サーバ＝RADIUS サーバ。EAP-TLS＝証明書で相互認証。

無線：Enterprise＝802.1X＋動的な鍵、Enhanced Open＝入力なしで暗号化、プライバシーセパレータ＝端末同士を遮断。

TLS 1.3：暗号スイート＝AEAD＋ハッシュ。DTLS＝UDP、IPsec＝ネットワーク層、SSH＝遠隔ログイン。

DNSSEC：権威が署名、リゾルバが検証。暗号化はしない。

メール：OP25B＝外向きの 25 番を止める、SMTP-AUTH＝送信時の認証、SPF＝DNS に IP、DKIM＝署名、DMARC＝失敗時の方針。

暗号化：PGP・S/MIME はアドレスごと、SMTP over TLS はサーバごと。受信は IMAPS。

出典：IPA 午前 II（このPDFの問題演習）／IPA「支援士試験 シラバス（案）Ver.0.1」